

Dokumentasi Kode Backend Tauco Cap Badak

Phase 1B B1-B10

Clean Architecture

Go + Gin

PostgreSQL

OpenAPI

Local-first

VERSI

1.0

TARGET

Backend Go

TANGGAL

3 Agustus 2026

SCOPE

Phase 1B B1-B4

Atribut	Nilai
Versi dokumen	3.0
Tanggal	3 Agustus 2026
Status kode	Phase 1B local complete, B0-B10
Runtime	Go, Gin, GORM, PostgreSQL, Redis
Mode	Local-first, shadow-mode

Backend belum menggantikan website production. Next.js masih membaca content lokal dan form production masih memakai Netlify Forms.

1. Komponen Runtime

```
HTTP API
-> security / CORS / rate limit / request ID / trace / metrics / recovery
-> generated OpenAPI transport
-> application use case
-> cached repository
-> PostgreSQL + Redis

Worker
-> atomic PostgreSQL job claim
-> bounded goroutine pool
-> contact email/activity atau media variants
-> retry, dead-letter, replay
-> retention purge saat startup dan setiap 24 jam
```

Process yang tersedia:

Command	Fungsi
backend/cmd/api	Public REST API
backend/cmd/worker	Durable background worker
backend/cmd/migrate	Versioned SQL migration
backend/cmd/seed	Import content Phase 1A
backend/cmd/media-import	Ingest media internal, bukan HTTP upload
backend/cmd/ops	Dead-job replay dan targeted cache purge
backend/cmd/loadcheck	Cold/warm local performance baseline

2. Struktur Folder dan Fungsi

```
backend/
|-- cmd/                executable entry point
|   |-- api/            HTTP API dan graceful shutdown
|   |-- worker/         background job serta retention loop
|   |-- migrate/        apply/rollback/version SQL migration
|   |-- seed/           import konten Phase 1A ke PostgreSQL
|   |-- media-import/   ingest gambar melalui CLI internal
|   |-- ops/            replay job dan invalidasi cache
|   |-- loadcheck/      baseline cold/warm API lokal
|-- internal/
|   |-- composition/    wiring dependency dan lifecycle process
|   |-- delivery/api/   handler serta type hasil OpenAPI generator
|   |-- contract/requestmeta/ request ID dan problem instance
|   |-- content/        page domain, reader, importer, repository
|   |-- catalog/        product domain, reader, cursor, repository
|   |-- contact/        validasi intake, transaksi, email/activity
|   |-- jobs/           durable queue, lease, retry, worker pool
|   |-- media/          ingest, image processor, storage, repository
|   |-- audit/          boundary activity log
|   |-- platform/       adapter teknis bersama
|       |-- cache/      Redis cache-aside dan observasi
|       |-- config/     environment configuration
|       |-- database/   GORM, SQL migration, connection pool
|       |-- email/      SMTP sender
|       |-- httpmiddleware/ CORS, rate limit, headers, access log
|       |-- httpserver/ Gin router, trace, recovery, server
|       |-- logging/    structured log dan redaction
|       |-- observability/ Prometheus registry
|       |-- ratelimit/  Redis limiter dan local fallback
|-- migrations/         versioned SQL dan embedded migration
|-- openapi/            source contract dan generator config
|-- docs/               operations serta security runbook
|-- compose.yaml        PostgreSQL, Redis, dan Mailpit lokal
|-- Dockerfile          multi-stage build, scratch runtime
```

Folder fitur seperti `content`, `catalog`, `contact`, `jobs`, dan `media` memiliki `domain`, `application`, serta adapter yang diperlukan fitur itu. Folder `platform` hanya berisi kemampuan teknis yang dapat dipakai lintas fitur. `composition` menjadi satu-satunya tempat yang memilih implementasi konkret dan menyambungkannya.

Fungsi file pusat

File	Fungsi
<code>cmd/api/main.go</code>	Membaca environment, membuat <code>composition.App</code> , menangani signal, menjalankan HTTP server.
<code>composition/app.go</code>	Membuka PostgreSQL/Redis, membuat repository/use case/middleware, mendaftarkan route, menutup resource.
<code>composition/operations.go</code>	Readiness, autentikasi metrics, dan snapshot operasional.

File	Fungsi
<code>delivery/api/api.gen.go</code>	Type dan interface HTTP hasil OpenAPI; tidak diedit manual.
<code>delivery/api/public_read.go</code>	Pemetaan use case page/product menjadi response HTTP, ETag, 304, dan problem response.
<code>delivery/api/contact.go</code>	Strict body validation dan pemetaan contact intake menjadi response HTTP.
<code>content/repository/cached.go</code>	Decorator cache page di atas PostgreSQL.
<code>catalog/repository/cached.go</code>	Decorator cache list/detail product di atas PostgreSQL.
<code>contact/application/intake.go</code>	Validasi submission dan orkestrasi transaksi idempotent.
<code>jobs/application/worker.go</code>	Claim batch, bounded goroutine, heartbeat, success/retry/dead state.
<code>media/application/pipeline.go</code>	Orkestrasi normalized original dan pembuatan variant.
<code>platform/httpserver/router.go</code>	Urutan middleware dasar, liveness, 404/405, serta recovery.
<code>platform/observability/metrics.go</code>	Counter/gauge/latency Prometheus tanpa PII.

3. Clean Architecture

Layer	Isi
<code>domain</code>	Entity, value, dan invariant
<code>application</code>	Use case serta interface/port
<code>delivery</code>	HTTP DTO, generated OpenAPI, error mapping
<code>repository</code>	PostgreSQL dan cache decorator
<code>platform</code>	Database, Redis, HTTP, email, logging, limiter
<code>composition</code>	Concrete dependency wiring dan lifecycle

Domain dan application tidak mengimpor Gin, GORM, Redis, AWS SDK, atau Zap. Architecture test menjaga arah dependency ini.

4. Flow Backend dan Aplikasi

4.1 Startup API lokal

```
npm backend:dev
  -> wrapper memuat backend/.env
  -> cmd/api memvalidasi config dan secret
  -> composition membuka PostgreSQL serta Redis
  -> composition membangun repository, use case, limiter, metrics, router
  -> HTTP server listen dan menunggu shutdown signal
  -> shutdown menghentikan server lalu menutup pool PostgreSQL/Redis
```

Startup gagal cepat bila config wajib atau PostgreSQL tidak valid. Redis boleh gagal saat request karena cache dan limiter memiliki jalur fail-open/fallback, tetapi URL serta client tetap harus dapat dibuat saat composition.

4.2 Public content melalui Go API lokal

```
HTTP GET
  -> request ID + traceparent
  -> access log + metrics + security headers + CORS
  -> privacy-safe rate limit
  -> generated OpenAPI handler
  -> content/catalog PublishedReader
  -> Redis cache-aside
      hit -> validasi domain -> response
      miss -> PostgreSQL published revision -> isi cache -> response
      error/corrupt -> PostgreSQL -> perbaiki cache bila memungkinkan
  -> ETag cocok menghasilkan 304; selain itu JSON 200
```

Redis bukan source of truth. Hanya revision yang ditunjuk sebagai `published` di PostgreSQL yang dapat keluar melalui API. Product slug yang tidak ditemukan menjadi RFC 7807 `404`, bukan response kosong.

4.3 Contact API lokal dan worker

```
POST /api/v1/contact-messages
  -> CORS + contact rate limit + strict Content-Type/body/query
  -> validasi field, consent, honeypot, Idempotency-Key
  -> satu transaksi PostgreSQL
      contact_messages
      background_jobs: contact.email_notification
      background_jobs: contact.activity_log
  -> 201 segera, tanpa menunggu email

worker
  -> claim job dengan SKIP LOCKED + lease
  -> channel bounded -> dua goroutine default
  -> ambil contact berdasarkan ID
  -> SMTP email atau append activity log
  -> success | retry dengan backoff | dead-letter
```

Replay memakai idempotency digest sehingga retry browser tidak menggandakan pesan. Job hanya menyimpan ID pesan; nama, email, telepon, dan isi pesan tidak disalin ke payload antrean atau metrics. Retention loop menghapus pesan yang jatuh tempo dalam batch 100 saat worker mulai dan setiap 24 jam.

4.4 Media lokal

```
media-import CLI
-> batas ukuran + magic byte + decode validation
-> orientasi EXIF + re-encode PNG tanpa metadata
-> simpan normalized original secara immutable
-> transaksi media_assets + media.generate_variants job
-> worker membuat WebP 320/640/1280 tanpa upscale
-> semua sukses: ready; error: failed dan dapat di-retry
```

Tidak ada endpoint upload pada Phase 1B. Local storage adalah default; port S3-compatible sudah tersedia tetapi belum dihubungkan ke provider remote.

4.5 Operations

```
/health/live      process hidup, tanpa dependency call
/health/ready     PostgreSQL wajib; Redis/storage dapat degraded
/internal/metrics bearer token -> Prometheus text
backend:ops       replay dead job atau naikan cache generation tag
```

Request ID selalu tersedia. Trace ID diteruskan hanya bila `traceparent` valid. Structured log dan metrics tidak menyimpan body, credential, raw IP, atau PII.

4.6 Flow website production saat ini

```
content/*.json
-> LocalContentSource + Zod saat build/render
-> Next.js App Router menghasilkan initial HTML, metadata, JSON-LD
-> Netlify menyajikan halaman publik
-> browser menerima copy SEO tanpa menunggu client-side fetch

form kontak browser
-> validasi React
-> POST URL-encoded ke /__forms.html
-> Netlify Forms inbox + email notification
```

Jadi production Phase 1A belum memanggil Go API. Backend Phase 1B berjalan lokal sebagai shadow system agar schema, contract, worker, cache, dan keamanan siap sebelum cutover. Pada Phase 1C, implementasi `ContentSource` dapat diganti dengan adapter API tanpa mengubah komponen page. Cutover form ke contact API baru dilakukan pada gate terpisah setelah backend remote stabil.

5. Route Aktif

```
GET /health/live
GET /api/v1/home
GET /api/v1/about
GET /api/v1/tauco-guide
GET /api/v1/products
GET /api/v1/products/{slug}
POST /api/v1/contact-messages
```

Readiness dan protected metrics baru diaktifkan pada B9. Tidak ada route admin, login, inventory, order, atau upload media pada Phase 1B.

Public response memakai generated OpenAPI type, envelope `data/meta`, `X-Request-ID`, strong `ETag`, conditional `304`, dan RFC 7807 untuk error.

6. Database

Schema aplikasi adalah `tauco_app`. Migration saat ini:

```
version=4 dirty=false
```

Tabel utama:

Tabel	Tanggung jawab
<code>pages</code> , <code>page_revisions</code>	Published page revisions
<code>products</code> , <code>product_revisions</code>	Published product revisions
<code>contact_messages</code>	Pesan, consent, dan retention deadline
<code>background_jobs</code>	Durable queue dan lease state
<code>media_assets</code> , <code>media_variants</code>	Normalized original dan WebP output
<code>activity_logs</code>	Append-only activity

`tauco_runtime` dapat membaca published content, menerima contact, memproses job, dan mengubah state media. Role ini tidak dapat melakukan DDL, menulis published revision, atau menghapus data. Schema hanya berubah melalui SQL migration; `AutoMigrate` dilarang.

7. Contact Transaction

`POST /api/v1/contact-messages` menerapkan:

- JSON maksimal 32 KiB dan unknown field ditolak;
- `Idempotency-Key` wajib, 16-128 printable ASCII;
- validasi nama, email, telepon opsional, subject, message, consent, honeypot;
- HMAC digest untuk idempotency key dan SHA-256 untuk canonical payload;
- retention deadline tepat 12 bulan.

Satu transaksi PostgreSQL membuat:

```
1 contact_messages
1 contact.email_notification job
1 contact.activity_log job
```

Job hanya membawa `contactMessageId`, bukan PII. Replay payload sama aman dan tidak menggandakan row; key sama dengan payload berbeda menghasilkan `409`.

8. Durable Worker

Job diklaim dengan `FOR UPDATE SKIP LOCKED`. Default:

Setting	Nilai
Batch	10
Goroutine worker	2
Channel capacity	20
Lease	120 detik
Heartbeat	30 detik
Max attempts	8
Backoff awal/maksimum	30 detik / 30 menit
Jitter	+/-20 persen

Delivery bersifat at-least-once sehingga handler wajib idempotent. Lease yang expired dapat direclaim. Kegagalan berulang menjadi `dead`; replay mengubahnya ke `retry` dan mencatat activity. Shutdown melepaskan lease yang belum selesai.

9. Media Pipeline

Media hanya masuk melalui CLI internal. Batas input:

- maksimal 10 MiB;

- JPEG, PNG, atau static WebP;
- magic byte dan actual decode harus cocok;
- maksimal 40 megapixel dan sisi 12.000 pixel;
- animated WebP, SVG, GIF, corrupt, dan truncated input ditolak.

Processor menerapkan orientasi EXIF, lalu encode ulang full-resolution menjadi PNG privat. Re-encode menghilangkan metadata EXIF/GPS. Worker membuat WebP pada width 320, 640, dan 1280. Target di atas source dilewati tanpa upscale.

Resize memakai maksimal dua goroutine. Object key bersifat content-addressed dan immutable. Local adapter memakai atomic file create; S3 adapter memakai conditional `If-None-Match: *`. Seluruh variant selesai sebelum status menjadi `ready`; partial failure menjadi `failed` dan dapat di-retry.

10. Redis Cache

Cache-aside dipasang pada page, product list, dan product detail:

- TTL dasar 5 menit dengan jitter +/-10 persen;
- `singleflight` menggabungkan concurrent cache miss;
- cached domain object divalidasi ulang setelah decode;
- corrupt cache diabaikan dan diperbaiki;
- Redis error selalu fail-open ke PostgreSQL.

Invalidation memakai generation tag, bukan key scan:

```
home
about
tauco-guide
products
product:{slug}
```

Publish/unpublish Phase 1C cukup menaikkan generation yang terkait.

11. Security Middleware

Kontrol	Implementasi
Public rate limit	60 request/menit/IP
Contact rate limit	5 request/jam/IP
Distributed counter	Atomic Redis Lua script
Redis failure	Local bounded fallback, maksimum 10.000 key
Client identifier	HMAC-SHA256 dari resolved IP

Kontrol	Implementasi
Trusted proxy	Exact CIDR dari environment
CORS	Exact origin allowlist, tanpa wildcard
Headers	nosniff, frame deny, referrer, permissions policy
GET body	Ditolak
Contact body/type	32 KiB, strict JSON, exact Content-Type
Panic	Recovered dan dipetakan ke generic RFC 7807

Raw IP, request body, token, credential, email, dan telepon tidak ditulis ke structured log.

12. Object Storage

Application hanya mengenal port berikut:

```
PutIfAbsent(context, key, contentType, bytes)
Get(context, key)
```

Adapter local dipakai pada shadow-mode. Adapter S3-compatible tersedia untuk pilot Supabase Storage/R2, tetapi belum mempunyai credential atau bucket remote.

13. Menjalankan Lokal

Dari root repository:

```
npm.cmd run backend:compose:up
npm.cmd run backend:migrate:up
npm.cmd run backend:migrate:version
npm.cmd run backend:seed:phase1a
npm.cmd run backend:dev
```

Terminal kedua untuk worker:

```
npm.cmd run backend:worker
```

Ingest media internal:

```
npm.cmd run backend:media:import -- --file "D:\gambar\produk.jpg" --alt "Foto produk"
```

Hentikan API/worker dengan `Ctrl+C` . Container dapat dihentikan tanpa menghapus volume:

```
npm.cmd run backend:compose:down
```

14. Environment Variable Utama

Variable	Fungsi
<code>DATABASE_URL</code>	PostgreSQL runtime login
<code>MIGRATION_DATABASE_URL</code>	Migration/seed login
<code>REDIS_URL</code>	Cache dan distributed rate limit
<code>CURSOR_HMAC_SECRET</code>	Signed pagination cursor
<code>CONTACT_HMAC_SECRET</code>	Contact idempotency digest
<code>RATE_LIMIT_HMAC_SECRET</code>	Privacy-safe rate key
<code>METRICS_BEARER_TOKEN</code>	Token khusus protected metrics
<code>CORS_ALLOWED_ORIGINS</code>	Exact comma-separated origins
<code>TRUSTED_PROXY_CIDRS</code>	Exact comma-separated proxy CIDR
<code>SMTP_HOST/PORT/FROM/TO</code>	Contact notification adapter
<code>MEDIA_LOCAL_ROOT</code>	Private local media object root

File `backend/.env` tidak masuk Git. Remote environment wajib memakai secret manager dan credential berbeda.

15. Test dan Quality Command

```
npm.cmd run backend:format
npm.cmd run backend:generate:check
npm.cmd run backend:test
npm.cmd run backend:test:integration
npm.cmd run backend:race
npm.cmd run backend:vet
npm.cmd run backend:lint
npm.cmd run backend:vuln
npm.cmd run backend:load
npm.cmd run backend:container:build
npm.cmd run backend:build
```

Integration test memakai PostgreSQL disposable dan Redis container nyata. Evidence sebelum unit-test cleanup mencakup transaction/idempotency, two-worker claim, crash/reclaim, dead-letter replay, media abuse/no-upscale/idempotency, cache fail-open, singleflight, generation invalidation, atomic concurrent rate limit, CORS, dan trusted proxy.

Atas instruksi owner setelah B10 lulus, unit-test files dan dependency Vitest dihapus. Architecture, acceptance, contract, migration, PostgreSQL/Redis integration, E2E, serta production smoke tetap tersedia.

16. Operations

- Liveness: `GET /health/live` tanpa dependency call.
- Readiness: `GET /health/ready` ; PostgreSQL wajib, Redis/storage boleh degraded.
- Worker probe: `npm.cmd run backend:worker:ready` .
- Metrics: `GET /internal/metrics` dengan metrics bearer token.
- Runbook: `backend/docs/OPERATIONS.md` .
- Security review: `backend/docs/SECURITY_REVIEW.md` .
- Final evidence: `PHASE_1B_QUALITY_REPORT.md` .

17. Boundary Berikutnya

- B11: optional remote pilot setelah instruksi owner.
- Phase 1C: Admin CMS, authentication, publishing, dan upload HTTP.

Tidak ada deployment, push, frontend cutover, contact cutover, atau cloud mutation pada implementasi B0-B10 ini.